

Digital Identity, Regulation & AI-Enabled Surveillance

Cyber Ethics and Law · Class Meeting 2

Lecture Agenda — Class Meeting 2

- Part 1 — Digital Identity: Concepts & Components
- Part 2 — Identity Proofing, Authentication & Federation
- Part 3 — Biometrics: Capabilities, Risks & Ethics
- Part 4 — Privacy Laws: FERPA, HIPAA, FTC, State Laws
- Part 5 — Professional Codes of Ethics
- Part 6 — AI-Enabled Surveillance & Proportionality
- Part 7 — Case Study: AI Proctoring System
- Part 8 — Regulatory Applicability Framework
- Part 9 — AI as Policy Reviewer
- Knowledge Checks are scattered throughout — answer slides follow immediately

PART 1

Digital Identity

Concepts, Components & the NIST Standard

What Is Digital Identity?

- Digital identity is far more than a username and password
- It is the full collection of attributes, credentials, and behaviors that uniquely represent a person in a digital system
- Organizations rely on identity systems to control access, enforce accountability, and meet legal obligations
- Identity decisions touch privacy, security, equity, and civil liberties simultaneously
- Authoritative U.S. standard: NIST Special Publication 800-63-4 (2024 Final)
 - Available at: csrc.nist.gov/pubs/sp/800/63/4/final

Core Components of Digital Identity (NIST SP 800-63-4)

Identifier	A unique string referring to a subject — username, employee ID, email address.
Credential	A data structure binding an identity to an authenticator (password, certificate, token).
Authentication Factor	Evidence used to verify identity: something you know, have, or are.
Identity Attribute	A characteristic of a subject — name, date of birth, role, affiliation.
Biometric	Physiological or behavioral data used to recognize a person (face, fingerprint, voice, gait).
Identity Proofing	The process by which an org verifies that a claimed identity corresponds to a real individual.

Core Components — Continued

Authenticator	Something the claimant possesses and controls to demonstrate identity — phone, smart card, hardware key.
Behavioral Characteristic	Patterns in how a user interacts with a system — typing cadence, mouse movement, navigation flow.
Device	Hardware associated with an identity and used as part of authentication.
Federation	Allows identity established by one trusted system to be accepted by another service.
Assurance Level	Degree of confidence in an identity claim. NIST defines IAL (proofing), AAL (auth), FAL (federation).

NIST SP 800-63-4 — Three Assurance Level Hierarchies

- IAL — Identity Assurance Level: how rigorously the identity was proofed
 - IAL1: Self-asserted — no verification of real-world identity
 - IAL2: Remote proofing with government document verification and facial comparison
 - IAL3: In-person proofing by trained staff with original documents + biometric capture
- AAL — Authentication Assurance Level: strength of the authentication mechanism
 - AAL2: Requires multi-factor authentication (MFA)
 - AAL3: Requires phishing-resistant hardware-bound authenticators (e.g., FIDO2 security keys)
- FAL — Federation Assurance Level: trustworthiness of federated identity assertions
 - FAL3: Holder-of-key assertion — cryptographically bound to the subject

PART 2

Identity Proofing, Authentication & Federation

Establishing and verifying who someone is

Identity Proofing — Establishing Who You Are

- Central question: "Who are you, and how does the organization confirm that?"
- IAL2 (Remote): document scan + live facial comparison — verifies identity without in-person visit
- IAL3 (In-person): trained staff review original documents; biometric capture on-site
- Proofing failures create critical vulnerabilities — impostors gain access to high-value systems
- Over-collection during proofing creates independent privacy risk — collect only what is necessary
- Re-proofing events may be required when account recovery suggests compromise

Authentication — Proving Control of an Identity

- Central question: "Can you demonstrate control of an authenticator bound to that identity?"
- Three factor categories:
 - Something You Know — password, PIN, security question (weakest)
 - Something You Have — OTP app, hardware token, smart card
 - Something You Are — fingerprint, face, voice (biometrics)
- MFA combines two or more factor categories — significantly stronger than single-factor
- AAL3 requires phishing-resistant auth: cryptographic challenge-response; stolen passwords cannot replay
- Common vulnerabilities: weak passwords, SMS OTP (SIM swap attacks), phishing of TOTP codes

Authentication Strength Comparison

Stronger Methods

- Hardware security keys (FIDO2 / WebAuthn)
- Smart card + PIN (PIV / CAC)
- Authenticator app (TOTP / HOTP)
- Certificate-based authentication
- Push-based auth with number matching

Weaker / Riskier Methods

- SMS one-time passwords — SIM swap risk
- Knowledge-based authentication (KBA)
- Passwords alone (no second factor)
- Email magic links — email compromise risk
- Security questions — often publicly guessable

Federation — Trusted Identity Across Domains

- Federation: identity established by one system (Identity Provider / IdP) accepted by another (Relying Party)
- Common protocols: SAML 2.0, OpenID Connect (OIDC), OAuth 2.0
- Example: "Sign in with Google" — Google asserts your identity to a third-party app
- FAL levels: FAL1 (no encryption required) → FAL2 (assertion encrypted) → FAL3 (holder-of-key)
- Federation risks: a compromised IdP exposes every connected relying party simultaneously
- Privacy concern: federation can enable cross-organizational tracking — users often unaware of data flows
- Ethical obligation: organizations must disclose federated identity arrangements in privacy notices

PART 3

Biometrics

Capabilities, Error Rates, Bias & Ethics

Biometric Modalities — What Systems Measure

- Physiological biometrics — fixed characteristics of the body:
 - Face geometry, landmarks, skin texture
 - Fingerprint ridge patterns and minutiae
 - Iris — unique ring patterns
 - Voice — acoustic features of speech
 - Gait — walking pattern and movement signature
- Behavioral biometrics — patterns in how someone interacts:
 - Keystroke dynamics: typing speed, rhythm, error patterns
 - Mouse movement and click patterns
 - Navigation and interaction behavior within software

The Irreplaceability Problem — A Foundational Security Distinction

 **A compromised password can be changed. A person's face or fingerprint cannot.**

- This is the most fundamental difference between biometric and non-biometric credentials
- Biometric data exposed in a breach creates a permanent vulnerability for that individual
- Biometric templates stored by vendors are high-value attack targets
- Cancelable biometrics (transformed templates) partially address this — but are not universal
- Long-term retention of biometric data amplifies breach risk — collect only what is necessary, delete promptly

Error Rates — Why Accuracy Matters Deeply

- No biometric system is perfect — two key error types exist in every system:
- False Match Rate (FMR) — system incorrectly accepts an impostor as the genuine user
 - A high FMR is a security failure — wrong person gains access
- False Non-Match Rate (FNMR) — system incorrectly rejects the genuine user
 - A high FNMR is an equity failure — legitimate user is denied service
- These two error rates trade off: tightening the threshold reduces FMR but raises FNMR
- Error rates must be measured and reported across demographic groups — overall accuracy masks group-level disparities
- NIST FRVT (Face Recognition Vendor Testing) has documented large accuracy gaps across commercially deployed systems

Demographic Bias in Biometric AI

- Multiple NIST studies find many facial recognition algorithms perform significantly worse for:
 - Women compared to men
 - Older individuals
 - People with darker skin tones
 - Individuals with certain disabilities affecting facial presentation
- Consequence: false flags and access denials disproportionately burden already marginalized groups
- Bias originates in non-representative training data — it propagates through every downstream deployment
- Ethical obligation: review vendor NIST FRVT test reports before procurement; demand demographic accuracy data
- ADA / Section 504 implications: accessibility failures in AI systems may constitute discrimination

Biometric Consent, Retention & State Laws

Consent Must Be Meaningful

Individuals must understand when biometrics are collected, for what purpose, and by whom. Consent buried in 50-page enrollment agreements does not meet this standard.

Texas CUBI Act & Washington My Health My Data Act

Similar frameworks requiring consent and limiting secondary use; Washington's law broadly covers health-adjacent data beyond HIPAA's scope.

Secondary Use Prohibition

Data collected for identity verification cannot be repurposed for marketing, research, or AI training without separate, explicit consent.

Retention Obligation

Biometric data must be destroyed when the purpose ends or within a defined maximum period — Illinois BIPA sets a 3-year cap.

Illinois BIPA (2008)

Requires written consent before collection; mandates a defined retention schedule; prohibits sale or profit from biometric data; provides a private right of action for violations.

KNOWLEDGE CHECK

A facial recognition system correctly identifies 998 out of 1,000 legitimate users but also incorrectly accepts 5 impostors per 1,000 attempts. Which metric describes the impostor-acceptance problem?

- A. False Non-Match Rate (FNMR)
- B. False Match Rate (FMR)
- C. Identity Assurance Level (IAL)
- D. Demographic parity gap

ANSWER

Which metric describes the impostor-acceptance problem?

Correct: B. False Match Rate (FMR)

FMR measures how often an impostor is incorrectly accepted as a genuine user — this is a security failure. FNMR measures how often a genuine user is rejected — an equity/usability failure. Both must be evaluated across demographic groups.

PART 4

Privacy Laws & Regulatory Obligations

FERPA · HIPAA · FTC · COPPA · State Laws

The Applicability Framework — Ask These Questions First

- Never assume a law applies — work through these five questions before concluding anything:

- 1. What type of organization is involved? (school, hospital, business, government)
- 2. What type of information is involved? (health, education, financial, biometric)
- 3. Whose information is it? (students, patients, consumers, employees)
- 4. What industry is involved? (education, healthcare, finance, retail)
- 5. What jurisdiction applies? (federal, which state(s), EU/UK)
- 6. What is being done with the data? (collecting, sharing, retaining, analyzing)

- Three common errors to avoid:

- Do NOT assume HIPAA applies simply because health information is involved
- Do NOT assume FERPA resolves every educational privacy question
- Do NOT assume every privacy problem equals a regulatory violation

FERPA — Family Educational Rights and Privacy Act (1974)

Who It Covers

Educational institutions that receive federal funding — K-12 schools and colleges/universities. Applies to "education records" directly related to a student and maintained by the institution.

Key Exceptions to Consent

School officials with legitimate educational interest; transfer to other schools; financial aid; judicial orders or lawfully issued subpoenas; health and safety emergencies.

Core Student Rights

Inspect and review records; request amendment of inaccurate records; consent to disclosure. Rights transfer to the student at age 18 (or enrollment in post-secondary school).

Enforcement

No private right of action — enforcement is through the U.S. Department of Education's Student Privacy Policy Office. Penalties can include loss of federal funding.

General Rule: Consent Required

An institution generally may not disclose education records without written consent of the eligible student (or parent if under 18).

AI Monitoring Relevance

Behavioral monitoring data generated by AI proctoring systems may constitute education records — if it is directly related to a student and maintained by the institution.

HIPAA — Health Insurance Portability and Accountability Act (1996)

Who It Covers

Covered Entities: healthcare providers, health plans, and healthcare clearinghouses that transmit health info electronically. Business Associates: vendors that create, receive, or transmit PHI on a covered entity's behalf.

Security Rule

Requires administrative, physical, and technical safeguards for electronic PHI (ePHI). Includes risk analysis, access controls, encryption, and audit controls.

Protected Health Information (PHI)

Individually identifiable health information in any form (electronic, paper, oral). Must be linked to a person — de-identified data is not PHI.

Breach Notification Rule

Covered entities must notify HHS and affected individuals within 60 days of discovering a breach of unsecured PHI. Breaches affecting 500+ individuals must also be reported to media.

Privacy Rule

Limits uses and disclosures of PHI; patients have rights to access and amend their records; covered entities must provide a Notice of Privacy Practices.

Common Misconception

HIPAA does NOT apply to employers, schools, life insurers, most wellness apps, or researchers — unless they qualify as a covered entity or business associate.

FTC Act § 5 — Federal Trade Commission Privacy & Security Enforcement

Legal Basis

Section 5 of the FTC Act prohibits "unfair or deceptive acts or practices" in commerce. The FTC uses this broad authority to enforce privacy and data security even without a specific statute.

Enforcement Actions

FTC has acted against companies for: failure to implement reasonable security; collecting more data than disclosed; sharing data contrary to privacy statements; deploying AI systems without adequate disclosure.

Deception

Misrepresenting data practices to consumers — e.g., saying "we never share your data" and then sharing it. Buried or unclear privacy disclosures can be deceptive.

2024-2026 FTC Focus Areas

Commercial surveillance rules; AI-generated content and impersonation; children's data; biometric information; dark patterns that manipulate consumer choices.

Unfairness

Causing substantial consumer injury that could not reasonably be avoided and is not outweighed by benefits. Failing to implement basic security measures causing a breach has been held unfair.

FTC Resources

Business guidance at: ftc.gov/business-guidance/privacy-security — covers data security, privacy notices, and sector-specific obligations.

COPPA — Childrens Online Privacy Protection Act

Who It Covers

Operators of websites and online services directed to children under 13, OR any operator with actual knowledge that it is collecting personal information from a child under 13.

Enforcement

FTC enforces COPPA with significant civil penalties — up to thousands of dollars per violation. Violations can result in tens of millions in total penalties.

Core Requirement

Verifiable parental consent must be obtained before collecting, using, or disclosing personal information from children under 13.

Education Technology

EdTech platforms used in K-12 schools must comply if students are under 13. Schools can consent on behalf of parents for educational purposes under the school exception — but limits apply.

Data Minimization

Cannot condition participation on providing more personal information than is reasonably necessary for the activity.

2024 COPPA Rule Updates

FTC has proposed updates addressing persistent identifiers, limits on use of school-authorized data for commercial purposes, and expansion of data minimization requirements.

State Privacy Laws — A Patchwork Landscape (2026)

California — CCPA + CPRA

Comprehensive consumer rights: access, deletion, correction, portability, opt-out of sale and sharing. Sensitive data (including biometrics) subject to heightened protections. Enforced by California Privacy Protection Agency (CPPA).

Washington — My Health My Data Act

Broadly covers health data beyond HIPAA — applies to any business collecting consumer health data in Washington. Requires consent for collection; opt-in for sharing. Includes geolocation near health facilities.

Virginia — VCDPA

Consumer rights to access, delete, correct, and opt out of targeted advertising. Requires data protection assessments for high-risk processing including profiling and biometric data.

Colorado, Connecticut, Texas, Montana, Oregon

Comprehensive privacy frameworks similar to Virginia's VCDPA — consumer access/deletion/opt-out rights, data protection assessments for high-risk processing.

Illinois — BIPA

Biometric-specific: requires written consent; retention schedule; prohibits profit from biometric data; private right of action. Has produced significant litigation and settlements (Meta: \$650M).

Organizational Impact

Organizations operating nationally may be subject to multiple overlapping state obligations simultaneously. Biometrics and AI profiling attract the most stringent requirements.

GLBA & ECPA — Additional Federal Frameworks

GLBA — Gramm-Leach-Bliley Act

- Applies to financial institutions
- Requires annual privacy notices to consumers about data sharing practices
- Safeguards Rule (updated 2023): must implement a written information security program
- Specific technical controls now required: MFA, encryption, access controls, penetration testing
- Relevant when schools handle student financial aid or payment data

ECPA — Electronic Communications Privacy Act

- Governs interception of electronic communications (Wiretap Act, Stored Communications Act)
- Employer monitoring generally permitted with notice or consent on employer-provided systems
- Monitoring student communications on institutional systems raises ECPA questions
- Key debate: does AI behavioral monitoring during online exams constitute "interception"?
- Many states have stricter wiretap laws requiring all-party consent

KNOWLEDGE CHECK

A university health center stores student medical records. Which law most directly governs the privacy of those records?

A.

FERPA — because it is a university and these are student records

B.

HIPAA — because the health center qualifies as a covered-entity healthcare provider

C.

FTC Act § 5 — because the university is a commercial operator

D.

COPPA — because some students may be under 18

ANSWER

Which law governs a university health center's medical records?

Correct: B. HIPAA

A university health center is a covered-entity healthcare provider that transmits health info electronically. FERPA may also apply when the same record qualifies as an education record — but HIPAA governs the clinical medical record. The common error is assuming FERPA resolves everything simply because it is a school.

PART 5

Professional Codes of Ethics

ACM · (ISC)² · ISACA · EC-Council · IEEE

Why Codes of Ethics Matter for Technical Professionals

- Laws set minimum legal floors — ethics set aspirational professional ceilings
- Technical professionals hold enormous power over individuals, organizations, and society
- Codes of ethics provide guidance in three critical scenarios:
 - No law clearly applies to the situation
 - The law permits something that still causes harm
 - The law has not yet caught up with the technology
- Codes also establish accountability — violation can result in loss of professional certification
- Ethical failure in cybersecurity and identity systems can harm millions of people at scale
- The cybersecurity professional's unique position: often one of the few people who understands the true risk

ACM Code of Ethics (2018) — Core Principles

1.1 Contribute to Society and Human Well-Being

Computing professionals must consider all stakeholders — not only the organization paying for the system. Harms to society, even unintended ones, must be weighed and minimized.

1.2 Avoid Harm

Identify and mitigate potential harms in system design and deployment. Some harm may be justifiable when weighed against benefits — but the analysis must be done explicitly, not assumed away.

1.3 Be Honest and Trustworthy

Do not misrepresent system capabilities, accuracy, or limitations. Honest disclosure includes informing clients and employers of technical risks they may not understand.

1.6 Respect Privacy

Only collect personal data needed for the work. Protect it with appropriate security. Do not use data for purposes beyond what was originally authorized.

1.7 Honor Confidentiality

Protect confidential information obtained in a professional capacity — unless disclosure is required to prevent serious harm or is required by law.

Professional Responsibility

Computing professionals must push back against organizational directives that violate ethical principles. Compliance with a directive does not absolve ethical responsibility. See [acm.org/code-of-ethics](https://www.acm.org/code-of-ethics)

(ISC)² Code of Ethics — Four Mandatory Canons

Canon 1 (Paramount): Protect Society

Protect society, the common good, necessary public trust and confidence, and the infrastructure. When canons conflict, Canon 1 prevails — society comes before employer, client, or personal interest.

Canon 2: Act Honorably

Act honorably, honestly, justly, responsibly, and legally. This includes refusing to implement systems known to be deceptive or harmful, even if ordered to do so by an employer.

Canon 3: Serve Principals Diligently

Provide diligent and competent service to principals (employers and clients). This obligation exists but is subordinate to Canons 1 and 2 when they conflict.

Canon 4: Advance the Profession

Advance and protect the profession through ethical behavior, sharing knowledge appropriately, and supporting the security community.

Practical Implication — Surveillance Scenario

A CISSP ordered to implement a covert surveillance system that harms the people it monitors must refuse — Canon 1 overrides Canon 3 (service to employer). Violation can result in certification revocation.

Scope

Applies globally to all (ISC)² credential holders: CISSP, CCSP, SSCP, CAP. See isc2.org/ethics

ISACA Code of Professional Ethics

Who It Applies To

All ISACA members and certification holders: CISA (auditor), CISM (security manager), CRISC (risk), CGEIT (IT governance).

Objectivity

Maintain competency and objectivity — do not advocate for specific vendor solutions or allow personal relationships to influence professional judgments.

Support Appropriate Standards

Members must support implementation of appropriate standards, procedures, and controls for IT governance and risk management — even when this conflicts with what management prefers.

Confidentiality

Protect confidential information obtained in a professional capacity. Disclosure is appropriate when required by legal authority or professional obligation.

Duty to Inform

Obligation to inform appropriate parties of all material facts related to IT governance, control, and risk — including risks that management may prefer not to disclose.

AI Governance Relevance

CISM and CRISC professionals who identify AI system risks — including bias, accuracy failures, or disproportionate data collection — have an affirmative obligation to disclose those risks regardless of employer preference.

EC-Council Code of Ethics — CEH & Offensive Security Standards

Authorization is a Prerequisite

Members must never access systems, networks, or devices without explicit written permission from the owner. The absence of a "no trespassing" sign is not authorization.

Advance the Profession

Share knowledge for the betterment of the security profession — through responsible disclosure, community participation, and mentorship.

Confidentiality of Assessment Findings

All information discovered during authorized security assessments must be kept confidential. Findings may only be disclosed to the authorizing party or as legally required.

Relevance to Surveillance Systems

Security professionals must clearly distinguish between authorized security monitoring (with notice and consent) and unauthorized surveillance. The technical capability to monitor does not confer the right to do so.

No Malicious Use of Skills

Skills and knowledge must not be used to compromise systems, steal data, or cause harm — regardless of whether the action would benefit the practitioner.

Competing Obligations

A CEH who discovers that an employer is conducting unlawful covert surveillance faces competing obligations between confidentiality and legal compliance — ethical frameworks provide no easy answer; legal counsel is essential.

IEEE Code of Ethics (2020 Revision)

Hold Paramount: Public Safety & Welfare

Engineers must hold paramount the safety, health, and welfare of the public. If a factor threatens the public, the engineer has an obligation to disclose it — even at personal professional risk.

Improve Understanding of Technology

Improve public understanding of technology and its societal consequences — including unintended consequences of AI systems deployed at scale.

Be Honest and Realistic

State claims about systems honestly and realistically — including limitations and failure modes. Overstating an AI system's accuracy to secure a contract violates this principle.

Treat All Persons Fairly

Avoid harassment and discrimination; consider the needs of all groups affected by technology, including those who are not at the table when design decisions are made.

Avoid Conflicts of Interest

Avoid real or perceived conflicts of interest. Disclose potential conflicts to affected parties as soon as they are recognized.

IEEE AI Standards Work

IEEE P7001 (Transparency of Autonomous Systems) and P7003 (Algorithmic Bias Considerations) — active standards directly relevant to biometric AI deployment decisions. See [ieee.org](https://www.ieee.org)

Ethics Codes — Quick Reference Comparison

ACM & IEEE (Engineers)

- Contribute to society — all stakeholders
- Avoid harm; assess unintended consequences
- Respect privacy; collect minimum data
- Be honest about system limitations
- Applies to all computing/engineering professionals

(ISC)² (Security Practitioners)

- Society always comes first (Canon 1 paramount)
- Employer obligation subordinate to societal duty
- Must refuse unethical directives regardless of source
- Applies to all (ISC)² credential holders globally
- Violation → certification revocation

KNOWLEDGE CHECK

A CISSP professional is ordered by their employer to implement a covert employee surveillance system they believe causes unjustified harm. Under the (ISC)² Code, what is the correct action?

A.

Comply — Canon 3 requires diligent service to principals (employer)

B.

Refuse — Canon 1 protecting society overrides the obligation to the employer

C.

Implement, but document your objection in writing

D.

Ask (ISC)² for permission before deciding

ANSWER

What should a CISSP do when ordered to implement a harmful covert surveillance system?

Correct: B. Refuse — Canon 1 is paramount

Canon 1 (Protect society) overrides Canon 3 (serve principals). The CISSP must decline to implement a system that harms people without adequate justification, even when directed by their employer. This is not optional — it is a mandatory ethical obligation with certification consequences for non-compliance.

PART 6

AI-Enabled Surveillance & Proportionality

The spectrum of monitoring and when it becomes unjustified

The Surveillance Spectrum — From Minimal to Pervasive

- Security monitoring exists on a spectrum — justification required increases with intrusiveness
- Least intrusive — generally uncontroversial:
 - Reviewing authentication logs (login times, IP addresses)
 - Increasing endpoint logging during an active incident investigation
- Moderate — notice and purpose required:
 - Monitoring browsing activity on employer-provided systems
 - Capturing screenshots at intervals during a flagged security event
- Highly intrusive — strong justification required:
 - Activating webcam monitoring during work hours
 - AI analysis of gaze direction, body movement, background audio
 - Continuous location tracking via device GPS
- Key principle: more monitoring is NOT automatically better security — marginal benefit must justify marginal intrusion

The Central Proportionality Question

? Could a less intrusive control achieve the same security objective?

- Proportionality: the level of intrusiveness must match the severity of the risk being addressed
- Academic integrity is a real concern — but does it justify biometric capture + continuous behavioral AI in students' homes?
- Alternative controls exist: in-person testing, randomized question pools, lockdown browsers without biometrics
- When less-intrusive alternatives achieve the same goal, deploying more invasive systems requires additional justification
- The burden of justification increases as the intrusiveness of the monitoring increases
- Organizations must document proportionality reasoning — especially before deploying biometric or AI-based systems

AI Inference — The "More Than You Think" Problem

- AI behavioral monitoring systems can infer attributes far beyond what appears to be collected
- A system capturing keystrokes, gaze, movement, and audio can potentially infer:
 - Mental health status — anxiety indicators, attention difficulties, signs of distress
 - Disability status — motor impairment, visual conditions, ADHD-related patterns
 - Emotional state — stress levels, engagement, frustration
 - Demographic attributes — race, sex, age inferences from behavioral patterns
- These inferences are sensitive personal data — even if the raw inputs seemed innocuous
- EU GDPR and comprehensive state privacy laws restrict processing of inferences about health, disability, and protected characteristics
- Vendor obligation: disclose what inferences the AI generates — organizations must evaluate whether each inference is justified

Transparency, Notice & the Consent Problem

- Individuals have a right to meaningful notice of when they are monitored and what data is collected
- Legal notice requirements:
 - FTC Act: failure to disclose monitoring practices can constitute deception
 - ECPA: interception without consent or notice may be unlawful
 - State wiretapping laws: many states require all-party consent
 - GDPR (EU data subjects): Articles 13-14 require detailed notice at or before collection
- Notice buried in enrollment agreements does not constitute meaningful consent for biometric monitoring
- Power imbalance problem: students cannot practically refuse — refusal means failure to complete coursework
- Meaningful consent requires a genuine, realistic alternative — not merely a theoretical opt-out
- Conclusion: in many educational monitoring contexts, true informed consent may be structurally impossible

KNOWLEDGE CHECK

A proctoring vendor's contract states it may retain session recordings to improve its AI models. In Illinois, which law most directly requires explicit written consent before this secondary use?

A.

FERPA — because the recordings are education records

B.

HIPAA — because behavioral data can reveal health information

C.

Illinois BIPA — because facial recordings are biometric identifiers

D.

ECPA — because the recordings constitute electronic communications

ANSWER

Which Illinois law requires explicit consent for retaining facial recordings to train AI models?

Correct: C. Illinois BIPA

BIPA requires written consent before collecting biometric identifiers (including facial geometry captured via video), mandates a defined retention schedule, and prohibits using biometric data to profit or for purposes beyond those originally disclosed. Using student facial recordings to train commercial AI models would require separate, explicit BIPA-compliant consent.

PART 8

Regulatory Applicability Framework

A step-by-step methodology for real-world analysis

Step-by-Step Regulatory Analysis

Step 1: Identify the Organization Type

Government entity → constitutional/administrative overlay. Educational institution receiving federal funding → FERPA. Healthcare covered entity or business associate → HIPAA. Financial institution → GLBA. Any commercial entity → FTC Act generally applies.

Step 2: Identify the Data Type

Biometrics → state biometric laws (BIPA, etc.) likely apply. Children's data → COPPA may apply. Education records → FERPA. Health data → HIPAA and/or state health privacy laws. Personal data of CA residents → CCPA/CPRA applies.

Step 3: Identify the Activity

Collection → consent and notice requirements. Sharing with third parties → DPA/BAA requirements. Automated decision-making → GDPR Art. 22, state opt-out rights. Profiling and inferences → sensitive data handling obligations.

Step 4: Identify the Jurisdiction

Federal law: minimum floor applies throughout the U.S. State laws: apply based on where data subjects are located. GDPR: applies to processing EU residents' data regardless of where the organization is located.

Step 5: Document the Analysis

Privacy Impact Assessment (PIA) or Data Protection Impact Assessment (DPIA) documents the reasoning. Organizations must demonstrate they considered applicable law — not just that they happened to comply.

Step 6: Review Periodically

Law changes. Technology changes. An analysis that was current 18 months ago may be outdated. PIAs should be reviewed when new systems are deployed or existing systems are materially modified.

Six Common Regulatory Analysis Errors

Error 1: "We have a privacy policy, so we're compliant"

A privacy policy is a disclosure document — compliance requires that your actual practices match what you disclosed. Policies and practices must align.

Error 2: "Our vendor handles the data, so our obligation ends"

Data controllers remain responsible for what processors do with data. Vendor contracts must include appropriate use restrictions, security requirements, and liability allocations.

Error 3: "HIPAA applies because health information is involved"

HIPAA only applies to covered entities and their business associates. A fitness app, school health office, or employer wellness program may hold health data without being subject to HIPAA.

Error 4: "Enrollment consent covers all subsequent data uses"

FERPA, BIPA, and state privacy laws require consent that is specific to the purpose, voluntary, and written. General enrollment consent does not authorize all future uses of student data.

Error 5: "We're a U.S. company, so GDPR doesn't apply to us"

GDPR applies to processing of EU residents' personal data regardless of where the processing organization is located. If you have EU students, GDPR is relevant.

Error 6: "The AI made the decision, so we're not liable"

Organizations are accountable for algorithmic decisions made on their behalf. Automated decision-making does not transfer liability to the technology — it remains with the deploying organization.

PART 9

AI as Policy Reviewer

Capabilities, Limitations & Professional Responsibility

Using AI Tools to Review Monitoring Policies

- AI tools (ChatGPT Edu, Claude, etc.) can assist in identifying potential issues in monitoring policies
- Useful AI review prompts for monitoring and technology proposals:
 - Identify unclear or ambiguous purpose statements
 - Flag data collection that exceeds the stated purpose
 - Identify secondary uses not covered by original consent
 - Note missing or vague retention timelines
 - Flag access control weaknesses or unclear authorization structures
 - Identify AI-generated inferences that may be sensitive attributes
 - Flag potential demographic bias and missing testing documentation
 - Identify transparency or notice deficiencies
 - Note governance and accountability gaps — who is responsible for what?

Critical Evaluation of AI Policy Review Output

AI Output Is a Starting Point, Not a Conclusion

AI tools can generate useful checklists and flag issues worth investigating — but they cannot replace professional judgment. Every AI-generated finding requires independent verification.

Confident but Wrong — Hallucination Risk

Large language models can cite non-existent cases, mischaracterize statute requirements, or apply the law of one state as if it applies everywhere — with full confidence.

False Positives

AI may flag issues that do not actually exist or are already addressed in the document. Accepting AI critique uncritically can waste time and undermine credibility.

Outdated Legal Analysis

AI training data has a cutoff date. Laws, regulations, and enforcement guidance issued after that date will not be reflected in the AI's output. Always check for recent developments.

Jurisdiction Gaps

AI may not reflect current law in specific jurisdictions, recent regulatory guidance, or enforcement priorities that postdate its training data.

Professional Accountability Cannot Be Automated

If you use AI in your compliance analysis, you remain responsible for verifying and standing behind the output. A cybersecurity professional cannot shift liability for an incorrect assessment to an AI tool.

KNOWLEDGE CHECK

You prompt an AI tool to review a vendor policy and it concludes: "FERPA does not apply because student data is anonymized." What is the most important next step before relying on this conclusion?

A.

Accept it — AI analyzed more text than you could review manually

B.

Verify independently whether the data meets FERPA's specific de-identification standard

C.

Ask the AI a follow-up question to confirm the answer

D.

Forward the conclusion to your compliance team without further review

ANSWER

What should you do before relying on an AI conclusion about FERPA anonymization?

Correct: B. Verify independently — FERPA has specific de-identification standards

FERPA's de-identification standard is specific and technical — AI tools can mischaracterize it. A qualified professional must confirm whether the anonymization actually meets FERPA requirements. AI output is a checklist, not a compliance determination. You remain professionally responsible for the analysis.

Eight Core Takeaways from This Lecture

- 1. Digital identity is a multi-layered system — NIST SP 800-63-4 defines the authoritative framework
- 2. Biometrics carry unique permanent risks — a compromised biometric cannot be reset or reissued
- 3. AI systems infer more than they explicitly collect — behavioral data enables sensitive attribute inference
- 4. Regulatory applicability is context-dependent — always apply the five-question framework first
- 5. Professional ethics codes impose obligations beyond legal minimums — society comes before employer
- 6. Surveillance must be proportionate — could a less intrusive control achieve the same goal?
- 7. AI tools assist analysis but cannot replace professional judgment — verify all AI-generated conclusions
- 8. Data controllers remain accountable — vendor contracts do not transfer legal or ethical responsibility

Discussion Questions

- 1. At what point does identity verification become surveillance? Where is the ethical line?
- 2. Should educational institutions be permitted to require biometric data as a condition of completing coursework?
- 3. If an AI proctoring system has documented demographic bias, does deploying it violate anti-discrimination law?
- 4. Can a student meaningfully consent to biometric monitoring when refusal means failing the course?
- 5. A CISSP believes a surveillance system they have been ordered to build is unethical — what should they do?
- 6. How should a privacy impact assessment change the design of a monitoring system?
- 7. What obligations does a college have when the proctoring vendor suffers a data breach?

Key References & Resources

- NIST SP 800-63-4 (Digital Identity Guidelines, 2024): csrc.nist.gov/pubs/sp/800/63/4/final
- FTC Privacy & Security Business Guidance: ftc.gov/business-guidance/privacy-security
- ACM Code of Ethics (2018): acm.org/code-of-ethics
- (ISC)² Code of Ethics: isc2.org/ethics
- ISACA Code of Professional Ethics: isaca.org/resources/isaca-journal
- IEEE Code of Ethics: ieee.org/about/corporate/governance/p7-8.html
- NIST FRVT Face Recognition Vendor Testing: nist.gov/programs-projects/face-recognition-vendor-testing-frvt
- Illinois BIPA (740 ILCS 14): ilga.gov — search Biometric Information Privacy Act
- FERPA Overview: ed.gov/policy/gen/guid/fpco/ferpa/index.html
- GDPR Full Text: gdpr.eu — Article 4 (definitions), Article 22 (automated decisions), Article 35 (DPIA)

End of Class Meeting 2

Questions & Discussion Welcome